

Reporte Ejecutivo de Gestión de Riesgos

Organización: Clínica privada **Alumno:** Maximiliano Díaz **LU:** 31059979

Resumen ejecutivo

La clínica cuenta con 120 empleados y atiende aproximadamente 800 pacientes por día. Se identificaron y evaluaron siete riesgos utilizando SimpleRisk Classic, considerando probabilidad, impacto, activos afectados, controles existentes y tratamiento. El análisis prioriza tres riesgos de nivel Alto.

Top 5 de riesgos por nivel

Prioridad	Riesgo	Nivel
1	Ransomware afecta los sistemas clínicos	Alto
2	Acceso no autorizado a historias clínicas	Alto
3	Filtración de datos de pacientes	Alto
4	Phishing y robo de credenciales	Medio
5	Interrupción de los sistemas clínicos	Medio

Amenaza externa: Caperucita Roja y el lobo feroz

Como analogía de amenaza externa, el lobo feroz representa un actor externo que intenta aprovechar vulnerabilidades para alcanzar un activo protegido. Caperucita Roja representa el activo/persona que debe ser protegido frente a esa amenaza. En la clínica, esta idea se relaciona con amenazas como ransomware, phishing y accesos no autorizados.

Plan de tratamiento: los tres cerditos como capas de defensa

La estrategia de tratamiento puede entenderse mediante la analogía de los tres cerditos: una defensa robusta no depende de una única barrera, sino de múltiples capas. Para la clínica se proponen controles preventivos, controles de detección y controles de recuperación, de forma que el fallo de una medida no implique automáticamente el compromiso de toda la organización.

Planes de acción

Plan	Fecha objetivo	Estado inicial
PLAN-01 Recuperación ante Ransomware	30/10/2026	0%
PLAN-02 Protección de historias clínicas	30/10/2026	0%
PLAN-04 Protección de datos de pacientes	30/10/2026	0%
PLAN-03 Gestión de proveedores	22/10/2026	0%

Recomendaciones prioritarias

- Fortalecer la prevención y recuperación ante ransomware mediante protección de endpoints, actualización, segmentación, mínimo privilegio, copias aisladas y pruebas de restauración.
- Reforzar el acceso a historias clínicas y la protección de datos de pacientes mediante autenticación, mínimo privilegio, monitoreo y registro de actividades.
- Capacitar al personal y reforzar los controles contra phishing.
- Mantener medidas de continuidad operativa y recuperación ante interrupciones.
- 5. Seguridad física prioritaria:** los centros de datos nunca deben ubicarse al lado de cocinas ni debajo de piletas, debido a los riesgos de incendio e inundación, respectivamente.

Criterio de priorización

Los riesgos fueron valorados con la metodología Classic de SimpleRisk. La prioridad se estableció a partir de la combinación de probabilidad e impacto y del nivel resultante en la herramienta. El tratamiento seleccionado para los riesgos principales es mitigar.